Préparation aux 10 minutes de questions

Réponses courtes, appuyées sur des fichiers. « Je ne sais pas » est une réponse acceptable quand l'artefact manque.

1. Pourquoi ne retenez-vous pas l'attribution à un groupe connu ? Aucune observation n'est discriminante, aucune source n'est indépendante ; l'unique rapprochement est une affirmation de la fiche BIN-02, non vérifiable (une seule ligne de balise : ni les 300 s ni la gigue ne se mesurent). (`Note-attribution.md`)

2. La piste du LISEZ-MOI ne confirme-t-elle pas FIN7 ? C'est une indication du dossier pédagogique, pas une preuve ; elle répète la fiche, donc ce n'est pas une seconde source. Consignée à part (`Indication-dossier-pedagogique.md`). Risque de biais de confirmation.

3. Pourquoi contester T1055.012 ? La ligne exacte est `CreateRemoteThread into explorer.exe RWX region`. Le Process Hollowing crée un nouveau processus suspendu et remplace sa mémoire (page ATT&CK) ; rien ici n'indique cela. On conclut à une injection par thread distant (T1055 parent). Sous-technique, auteur, lien avec BIN-002 : non démontrés.

4. Pourquoi T1070.001 devient-il T1685.005 ? ATT&CK v19 (publiée le 28 avril 2026 ; en mars 2026 la version en vigueur était la v18.1, où l'identifiant était T1070.001) classe « Clear Windows Event Logs » sous « Disable or Modify Tools » (Defense Impairment). Le validateur pySigma a signalé l'ancien identifiant. MISP et certaines entités OpenCTI portent encore l'ancien.

5. Le compte utilisé avant d'être créé : erreur ou compromission ? Plusieurs lectures : compte préexistant recréé (HYP-001), horloges décalées (HYP-002), donnée mal alignée (HYP-012). Impact : si HYP-001, le vol LSASS n'est pas l'origine de ce compte. Non tranché ; les sources utiles sont demandées dans la RFI-02 (ouverte, sans réponse).

6. Avez-vous analysé les binaires ? Non : les fiches seulement (« analyse des fiches fournies »). Aucun hash recalculé, aucun binaire exécuté.

7. Pourquoi écrire dans la production ? Autorisation générale du commanditaire le 2026-10-06, puis approbation explicite par opération le 2026-10-07, après identification des risques : enrichissement automatique (IPinfo borné par TLP AMBER, Google DNS sans garde donc aucun domaine créé), flux Jira filtré sur un label non utilisé, connecteur MISP en marche mais sans interrogation de MISP et événement dans une organisation distincte, seuils Wazuh. Retour arrière documenté, non exécuté.

8. Le TLP:RED d'OpenCTI est-il une isolation ? Non : c'est une garde d'enrichissement vérifiée dans le code du connecteur IPinfo. L'isolation vient de l'absence de domaines et du filtrage ; un label ou un TLP n'isole rien.

9. Les 15 règles Sigma sont-elles déployables ? Syntaxe valide, logique testée sur 410 événements (jeux écrits par l'équipe), adaptations Wazuh testées jusqu'en production. Non déployables telles quelles sur de vrais journaux Windows (champs et chemins à adapter), niveaux à réviser.

10. Quel est votre taux de faux positifs ? « Aucun faux positif sur 410 événements testés (Sigma) et sur 18 négatifs (Wazuh) » : exactement ce qui a été mesuré. Aucun taux de production.

11. Pourquoi seulement 8 indicateurs sur 40 ? Un indicateur exige un artefact d'observation ou une justification ; les autres entrées sont déclarées sans artefact ou de nature incertaine (IOC-025, 026). Ils restent des observables ou des attributs MISP. Les indicateurs sont expirés volontairement.

12. Où peut-on voir les résultats ? OpenCTI : rapport `/dashboard/analyses/reports/3ec91c0f-915b-4e1d-9cd9-c1c12c79f342`, incident `/dashboard/events/incidents/a2f66075-be6c-42a9-9524-d428833fd4c1`, filtre étiquette `challenge:helios-fictif`. MISP : événement 6. Wazuh : `rule.groups: helios_challenge`. Enquête : `/dashboard/workspaces/investigations/14c28507-2b09-48b8-9b36-c2dc2470d64a` (ouvrir avec `&withForces=false` pour la mise en page enregistrée) ; RFI : `/dashboard/cases/rfis`. Affichage contrôlé dans les trois interfaces les 2026-10-06 et 2026-10-07 (le graphe de connaissance est sur le rapport, la page de l'incident n'a pas d'écran graphe).

13. Le bundle STIX est-il un export MISP ? Dérivé de l'export MISP réel (78 objets), transformé et enrichi (152 objets) ; transformations T1 à T13 documentées. Pas un export « pur ».

14. Le seuil de 25 objets liés est-il atteint ? Oui sous la méthode conservatrice de l'équipe : **27 objets de renseignement** (campagne, 3 malwares, 3 outils, 4 infrastructures, 8 techniques, 8 indicateurs) reliés par des relations explicites dans une même composante ; 25 si l'on retire les 2 ajouts fondés sur le texte d'une alerte.

Avant l'ajout de 7 objets prouvés par les artefacts (2026-10-07) il y en avait 20 (24 avec les victimes). La définition n'a pas été fournie (RFI-05 ouverte). Aucun relation ni marquage n'est compté comme entité.

15. Quid des obligations réglementaires ? Conditionnelles : OIV (fourni par l'énoncé) : « sans délai » à l'ANSSI si un SIIV est touché (inconnu) ; NIS 2 non transposée d'après l'ANSSI (mars 2026), état ultérieur vérifié seulement sur des sources secondaires ; RGPD 72 h si données personnelles confirmées. Aucune déclaration réelle.

16. Qu'avez-vous mesuré en éco-responsabilité ? Rien de chiffré. Choix réels : infrastructure existante réutilisée, aucun serveur ajouté, conteneur de test supprimé, données de test étiquetées. Aucune économie revendiquée.

17. Quelles sont les limites finales ? Échantillons absents, source du RDP et contenu de la sortie inconnus, équipe et temps non communiqués, 25 objets liés démontré sous une méthode propre à l'équipe (définition non confirmée), dépôt Git non créé (non approuvé), TLP AMBER (MISP) contre RED (OpenCTI), aucune relecture du commanditaire (`00-Pilotage/Decisions-et-limites-finales.md`).

18. Qu'avez-vous appris des erreurs de test ? Deux erreurs de syntaxe d'`analysisd -t` (champs statiques, regex), puis trois passes de logtest : 26 sur 45, 40 sur 45, 45 sur 45 (décodeurs enfants, limites d'OS_Regex, regex PCRE2). Le validateur STIX rejetait tout à cause de schémas absents : défaut d'installation, pas du bundle. (`Plan-tests.md`)